

Две модели предоставления сервиса и что каждая означает юридически

09_Модель_сервиса_B2B_против_self-serve.md

Дата: 16.08.2026.

1. Аттестат провайдера: что он закрывает и что нет

Аттестат соответствия № 1068.00022.2024 выдан на автоматизированную информационную систему «**Инфраструктура**» **ООО «Интерфоника»** — то есть на систему провайдера. Ваша информационная система персональных данных (приложение, данные, процессы) — **самостоятельный объект защиты**, размещённый на этой инфраструктуре.

[ЗАКОН] Ч. 1 и 2 ст. 19 152-ФЗ: оператор при обработке обязан принимать меры, необходимые для защиты **своих** персональных данных, определяя актуальные угрозы применительно к **своей** информационной системе. Аттестат третьего лица эту обязанность не исполняет.

Разграничение ответственности

Слой	Кто закрывает	Подтверждается
Физическая защита ЦОД, контроль доступа в помещения	Провайдер	Аттестат
Сетевая сегментация, межсетевое экранирование, обнаружение вторжений (ViPNet IDS)	Провайдер	Аттестат + сертификаты СЗИ
Криптографическая защита каналов (ViPNet, KC2)	Провайдер — при подключении к его сети; иначе вы	Договор + лицензии
Резервирование питания, охлаждения, каналов	Провайдер	Аттестат
Аутентификация и разграничение доступа в приложении	Вы	Своя документация
Регистрация событий безопасности приложения	Вы	Своя документация
Контроль целостности, антивирусная защита на вашем узле	Вы (если узел ваш)	Своя документация
Определение уровня защищённости, модель угроз	Вы	Акт УЗ, модель угроз
Организационные меры: политика, ответственный, регламенты	Вы	Комплект документов

Слой	Кто закрывает	Подтверждается
Оценка эффективности мер (ч. 4 ст. 19), не реже раза в 3 года	Вы	Акт оценки

[РЕКОМЕНДАЦИЯ] Запросить у ООО «ИНТЕРФОНИКА» матрицу разграничения ответственности — перечень мер приказа ФСТЭК России от 18.02.2013 № 21 с указанием, какие закрывает провайдер, какие оператор. У зрелых провайдеров это готовый документ.

Без такой матрицы на вендорском аудите возникает типовая дыра: обе стороны полагают, что меру реализует другая, а фактически её не реализует никто. Аудитор ИНК проверяет это одним вопросом.

Минимальный комплект, который остаётся вашим при любом провайдере

Приказ о назначении ответственного · Политика обработки ПДн · Перечень обрабатываемых ПДн · Модель угроз · Акт определения уровня защищённости · Регламент реагирования на инциденты · Порядок уничтожения · Акт оценки эффективности мер · Договор поручения с провайдером.

Ни один из них аттестатом провайдера не заменяется.

2. Две модели предоставления сервиса

2.1. Сравнение

Критерий	B2B: обработка по поручению	Self-serve: подключение по ссылке
Ваша роль	Лицо, осуществляющее обработку по поручению (ч. 3 ст. 6)	Оператор
Правовое основание обработки	Основание оператора-заказчика	Собственного основания нет — ключевая проблема
Кто отвечает перед субъектом	Оператор-заказчик (ч. 5 ст. 6), вы — в порядке регресса	Вы напрямую
Проверяемость правомочий загружающего	Договор, реквизиты, ответственное лицо	Заверения анонимного пользователя
Ограничение ответственности	Договором, до согласованного лимита	С потребителями невозможно (ст. 16 ЗоЗПП)
Количество субъектов	Ограничено масштабом заказчика	Быстро превысит 100 000
Специальные категории ПДн	Запрещаются договором + контролируются	Неизбежно попадут

Критерий	B2B: обработка по поручению	Self-serve: подключение по ссылке
Вероятный уровень защищённости	УЗ-3 при договорном запрете спецкатегорий	УЗ-2 → сертифицированные СЗИ
Штраф за утечку (юрлицо)	3–5 млн ₽ при 1 000–10 000 субъектов	10–15 млн ₽ ; повтор — оборотный от 20 млн
Уведомление в РКН	Обязательно	Обязательно, с широким кругом категорий
Пригодность самозанятости	Условно (см. документ 06)	Непригодна

2.2. Почему при self-serve нет правового основания

Субъекты персональных данных — лица, упомянутые в загружаемых документах. У вас с ними нет никаких отношений: ни договора, ни согласия, ни законной обязанности.

В модели B2B это решается конструкцией поручения: основание есть у заказчика (трудовые отношения, договор, закон), и вы работаете под ним, не получая собственного согласия — так прямо устроена ч. 3 ст. 6.

При self-serve заимствовать основание не у кого. Загружающий пользователь может сам не быть оператором и не иметь права передавать эти данные. Его собственное согласие не помогает: он вправе дать согласие за себя, а персональные данные в документе принадлежат **третьим лицам**.

[СПОРНО] Рабочая конструкция существует — договор присоединения (ст. 428 ГК) в форме оферты, где пользователь: 1. заверяет (ст. 431.2 ГК), что является оператором либо надлежаще уполномочен оператором; 2. заверяет, что располагает правовым основанием и исполнил обязанность информирования субъектов; 3. поручает вам обработку в объёме, определённом офертой; 4. даёт согласие на привлечение субобработчиков по перечню.

Слабое место конструкции: **заверения анонимного лица практически не обеспечены**. Проверить их вы не можете, взыскать с физического лица по регрессу — как правило, тоже. При инциденте регулятор придёт к вам.

2.3. Что обязательно, если идти в self-serve

Архитектурно — до запуска, не после:

№	Мера	Зачем
1	Полностью stateless : документ не сохраняется, ключ не сохраняется	Утечь может только то, что хранится. Это снимает основную часть рисков разом
2	Режим irreversible по умолчанию	Ключ не формируется — нечего терять и нечего требовать
3	<code>spans[].text</code> выключен	Второй ключ деанонимизации не покидает сервер

№	Мера	Зачем
4	Аутентификация, ограничение частоты запросов, лимит объёма	Базовая защита от массового злоупотребления
5	Технический контроль состава: отказ в обработке при обнаружении признаков спецкатегорий	Удержание УЗ-3 вместо УЗ-2
6	Журнал операций без содержимого	Учёт по п. 1.7 приказа № 140

Пункты 2 и 3 уже реализованы 16.08.2026, пункт 6 — тоже. Пункты 1, 4, 5 — нет.

Юридически:

Регистрация ООО — обязательна, самозанятость непригодна · Оферта с заверениями и поручением обработки · Явный запрет спецкатегорий, биометрии и сведений, составляющих государственную тайну · Уведомление в РКН до запуска · Политика обработки ПДн в открытом доступе · Порядок реагирования на обращения субъектов · Возрастные ограничения и правила при возможной обработке ПДн несовершеннолетних.

2.4. Рекомендуемая последовательность

[РЕКОМЕНДАЦИЯ] **Не запускать self-serve до того, как реализован полностью stateless-режим.** В текущей архитектуре — задание с результатом и ключом в памяти, отсутствие аутентификации, отсутствие ограничения частоты — публичный запуск по ссылке означает принятие рисков, которые не покрываются ни договором, ни страхованием, а при статусе физического лица обращаются на личное имущество.

Разумный порядок: сначала B2B-модель с ИНК (роль обработчика, ответственность ограничена договором, объём контролируем) → на её выручке довести архитектуру до stateless → затем открывать self-serve уже на защищённой архитектуре и от юридического лица.

3. Оговорка

Конструкция «оферта с заверениями пользователя» в отношении персональных данных третьих лиц судебной практикой в России в достаточной степени не проверена. Оценка в п. 2.2 помечена как спорная. До публичного запуска необходима отдельная проработка оферты практикующим юристом по персональным данным.